



International Standard

ISO/IEC 15408-4

Information security, cybersecurity and privacy protection — Evaluation criteria for IT security —

Part 4: Framework for the specification of evaluation methods and activities

*Sécurité de l'information, cybersécurité et protection de la vie
privée — Critères d'évaluation pour la sécurité des technologies
de l'information —*

*Partie 4: Cadre de spécification de méthodes et activités
d'évaluation*

**Second edition
2026-05**



Please share your feedback about
the standard. Scan the QR code
with your phone or click the link
[Customer Feedback Form](#)

ISO/IEC 15408-4:2026(en)



COPYRIGHT PROTECTED DOCUMENT

© ISO/IEC 2026

All rights reserved. Unless otherwise specified, or required in the context of its implementation, no part of this publication may be reproduced or utilized otherwise in any form or by any means, electronic or mechanical, including photocopying, or posting on the internet or an intranet, without prior written permission. Permission can be requested from either ISO at the address below or ISO's member body in the country of the requester.

ISO copyright office
CP 401 • Ch. de Blandonnet 8
CH-1214 Vernier, Geneva
Phone: +41 22 749 01 11
Email: copyright@iso.org
Website: www.iso.org

Published in Switzerland

Contents

Page

Foreword	iv
Introduction	v
1 Scope	1
2 Normative references	1
3 Terms, definitions and abbreviated terms	1
4 General model of evaluation methods and evaluation activities	2
4.1 Concepts and model	2
4.2 Deriving evaluation methods and evaluation activities	3
4.3 Verb usage in the description of evaluation methods and evaluation activities	6
4.4 Conventions for the description of evaluation methods and evaluation activities	6
5 Structure of an evaluation method	6
5.1 Overview	6
5.2 Specification of an evaluation method	7
5.2.1 Overview	7
5.2.2 Identification of evaluation methods	8
5.2.3 Entity responsible for the evaluation method	8
5.2.4 Scope of the evaluation method	9
5.2.5 Dependencies	9
5.2.6 Required input from the developer or other entities	9
5.2.7 Required tool types	10
5.2.8 Required evaluator competences	10
5.2.9 Requirements for reporting	10
5.2.10 Rationale for the evaluation method	10
5.2.11 Additional verb definitions	12
5.2.12 Set of evaluation activities	12
6 Structure of evaluation activities	12
6.1 Overview	12
6.2 Specification of an evaluation activity	12
6.2.1 Unique identification of the evaluation activity	12
6.2.2 Objective of the evaluation activity	12
6.2.3 Evaluation activity links to SFRs, SARs, and other evaluation activities	13
6.2.4 Required input from the developer or other entities	13
6.2.5 Required tool types	13
6.2.6 Required evaluator competences	13
6.2.7 Assessment strategy	13
6.2.8 Pass/fail criteria	14
6.2.9 Requirements for reporting	15
6.2.10 Rationale for the evaluation activity	15
Bibliography	16

Foreword

ISO (the International Organization for Standardization) and IEC (the International Electrotechnical Commission) form the specialized system for worldwide standardization. National bodies that are members of ISO or IEC participate in the development of International Standards through technical committees established by the respective organization to deal with particular fields of technical activity. ISO and IEC technical committees collaborate in fields of mutual interest. Other international organizations, governmental and non-governmental, in liaison with ISO and IEC, also take part in the work.

The procedures used to develop this document and those intended for its further maintenance are described in the ISO/IEC Directives, Part 1. In particular, the different approval criteria needed for the different types of document should be noted. This document was drafted in accordance with the editorial rules of the ISO/IEC Directives, Part 2 (see www.iso.org/directives or www.iec.ch/members_experts/refdocs).

ISO and IEC draw attention to the possibility that the implementation of this document may involve the use of (a) patent(s). ISO and IEC take no position concerning the evidence, validity or applicability of any claimed patent rights in respect thereof. As of the date of publication of this document, ISO and IEC had not received notice of (a) patent(s) which may be required to implement this document. However, implementers are cautioned that this may not represent the latest information, which may be obtained from the patent database available at www.iso.org/patents and <https://patents.iec.ch>. ISO and IEC shall not be held responsible for identifying any or all such patent rights.

Any trade name used in this document is information given for the convenience of users and does not constitute an endorsement.

For an explanation of the voluntary nature of standards, the meaning of ISO specific terms and expressions related to conformity assessment, as well as information about ISO's adherence to the World Trade Organization (WTO) principles in the Technical Barriers to Trade (TBT) see www.iso.org/iso/foreword.html. In the IEC, see www.iec.ch/understanding-standards.

This document was prepared by Joint Technical Committee ISO/IEC JTC 1, *Information technology*, Subcommittee SC 27, *Information security, cybersecurity and privacy protection*, in collaboration with the European Committee for Standardization (CEN) Technical Committee CEN/CLC/JTC 13, *Cybersecurity and data protection*, in accordance with the Agreement on technical cooperation between ISO and CEN (Vienna Agreement).

This second edition cancels and replaces the first edition (ISO/IEC 15408-4:2022), which has been technically revised.

The main changes are as follows:

— minor typographical and editorial errors corrected.

A list of all parts in the ISO/IEC 15408 series can be found on the ISO website.

Any feedback or questions on this document should be directed to the user's national standards body. A complete listing of these bodies can be found at www.iso.org/members.html and www.iec.ch/national-committees.

Introduction

The model of security evaluation in ISO/IEC 15408-1 identifies that high-level generic evaluation activities are defined in ISO/IEC 18045, but that more specific evaluation activities (EAs) can be defined as technology-specific adaptations of these generic activities for particular evaluation contexts, e.g. for security functional requirements (SFRs) or security assurance requirements (SARs) applied to specific technologies or target of evaluation (TOE) types. Specification of such evaluation activities is already occurring amongst practitioners, and this creates a need for a specification for defining such evaluation activities.

This document describes a framework that can be used for deriving evaluation activities from work units of ISO/IEC 18045 and grouping them into evaluation methods (EMs). Evaluation activities or evaluation methods can be included in protection profiles (PPs) and any documents supporting them. Where a PP, PP-Configuration, PP-Module, package, or Security Target (ST) identifies that specific evaluation methods/evaluation activities must be used, the evaluators are required by ISO/IEC 18045 to follow and report the relevant evaluation methods/evaluation activities when assigning evaluator verdicts. As noted in ISO/IEC 15408-1, in some cases an evaluation authority can decide not to approve the use of particular evaluation methods/evaluation activities. In such a case, the evaluation authority can decide not to carry out evaluations following an ST that requires those evaluation methods/evaluation activities.

This document also allows for evaluation activities to be defined for extended SARs, in which case derivation of the evaluation activities relates to equivalent evaluator action elements and work units defined for that extended SAR. Where reference is made in this document to the use of ISO/IEC 18045 or ISO/IEC 15408-3 for SARs (such as when defining rationales for evaluation activities), then, in the case of an extended SAR, the reference applies instead to the equivalent evaluator action elements and work units defined for that extended SAR.

For clarity, this document specifies how to define evaluation methods and evaluation activities but does not itself specify instances of evaluation methods or evaluation activities.

Several governmental organizations have contributed to the development of this version of the Common Criteria for Information Technology Security Evaluations. As the joint holders of the copyright in the Common Criteria for Information Technology Security Evaluations (called CC), they hereby grant non-exclusive license to ISO/IEC to use CC in the continued development/maintenance of the ISO/IEC 15408 series of standards. However, these governmental organizations retain the right to use, copy, distribute, translate, or modify CC as they see fit. More information on these agencies can be found at <https://commoncriteriaportal.org/cc/copyright/index.cfm>.

Information security, cybersecurity and privacy protection — Evaluation criteria for IT security —

Part 4: Framework for the specification of evaluation methods and activities

1 Scope

This document specifies requirements and a standardized framework for specifying objective, repeatable and reproducible evaluation methods and evaluation activities.

This document does not specify how to evaluate, adopt, or maintain evaluation methods and evaluation activities. These aspects are a matter for those originating the evaluation methods and evaluation activities in their particular area of interest.

2 Normative references

The following documents are referred to in the text in such a way that some or all of their content constitutes requirements of this document. For dated references, only the edition cited applies. For undated references, the latest edition of the referenced document (including any amendments) applies.

ISO/IEC 15408-1, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 1: Introduction and general model*

ISO/IEC 15408-2, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 2: Security functional components*

ISO/IEC 15408-3:2026, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 3: Security assurance components*

ISO/IEC 18045:2026, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Requirements and methodology for IT security evaluation*

3 Terms, definitions and abbreviated terms

For the purposes of this document, the terms and definitions given in ISO/IEC 15408-1, ISO/IEC 15408-2, ISO/IEC 15408-3, ISO/IEC 18045 apply.

ISO and IEC maintain terminology databases for use in standardization at the following addresses:

- ISO Online browsing platform: available at <https://www.iso.org/obp>
- IEC Electropedia: available at <https://www.electropedia.org/>

4 General model of evaluation methods and evaluation activities

4.1 Concepts and model

ISO/IEC 18045 defines a generic set of work units that an evaluator carries out in order to reach a verdict for most of the assurance classes, families and components defined in ISO/IEC 15408-3. The relationship between the structure of a SAR in ISO/IEC 15408-3 and the work units in ISO/IEC 18045 is described in ISO/IEC 18045 and summarized in [Figure 1](#) showing that the derivation is flexible and not required to be simply 1:1).

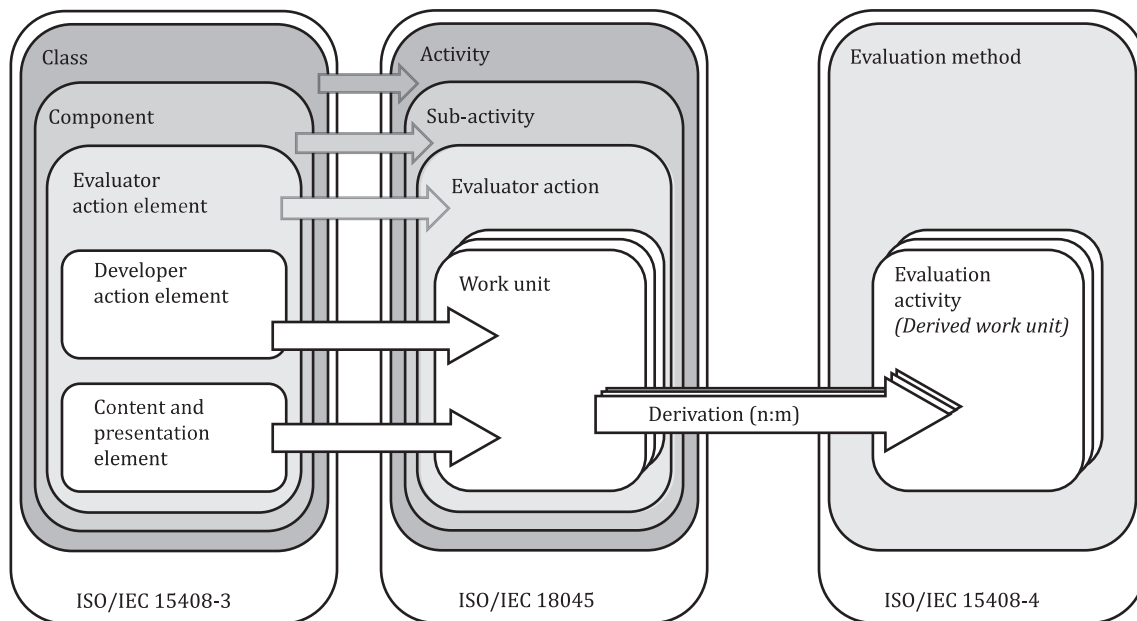


Figure 1 — Mapping of P3 and CEM to this document

For the purposes of defining new evaluation methods and evaluation activities, the main point to note is that each action (representing an evaluator action element in ISO/IEC 15408-3 or an implied evaluator action element) is represented in ISO/IEC 18045 as a set of work units that are carried out by an evaluator.

This document specifies the ways in which new evaluation activities can be derived from the generic work units in ISO/IEC 18045, and combined into an evaluation method that is intended for use in some particular evaluation context. A typical example of such an evaluation context is a particular TOE type or particular technology type.

EXAMPLE 1

- TOE type: a network device
- Technology type: specific cryptographic functions

If evaluation methods (EM) and evaluation activities (EA) are required to be used with a particular PP, PP-Module or PP-Configuration, then a PP or PP-Module or PP-Configuration shall identify this requirement in its conformance statement. If evaluation methods and evaluation activities are required to be used with a particular package, then the package shall identify this requirement in the security requirement section. If EMs and EAs are claimed by an ST as a result of that ST claiming conformance to a PP, PP-Configuration, or package, then the ST shall identify the EMs/EAs used in its conformance claim. No formal claim of conformance to this document made in any of these cases.

NOTE 1 The contents of PPs, PP-Modules, PP-Configurations and packages are described in more detail in ISO/IEC 15408-1.

ISO/IEC 15408-4:2026(en)

A PP, PP-Configuration, PP-Module or package may use more than one evaluation method or separate set of evaluation activities.

EXAMPLE 2 Multiple evaluation methods can be used where separate evaluation methods have been defined for cryptographic operations and for secure channel protocols used in a PP.

NOTE 2 Where exact conformance is used, ISO/IEC 15408-1 states that evaluation methods/evaluation activities are not allowed to be defined in a PP-Configuration: the evaluation methods/evaluation activities to be used are included in the PPs and PP-Modules and not in the PP-Configuration).

When a PP, PP-Module, PP-Configuration, or package identifies that certain evaluation methods/evaluation activities shall be used, then this is done using a standard wording that states the requirement and references the definition of the evaluation methods/evaluation activities to be used. An ST shall only identify required evaluation methods and evaluation activities that are included in a PP, PP-Module, PP-Configuration or package to which the ST claims conformance (i.e. the ST itself shall not add, modify or remove any evaluation methods or evaluation activities). An ST shall include identification of all evaluation methods/evaluation activities that it requires (i.e. including any that are required by PPs, PP-Modules, PP-Configurations, or packages to which the ST claims conformance), so that there is a single list that can be checked and referenced by evaluators and readers of the ST.

Evaluation methods and evaluation activities may be defined as part of a PP or required externally in a different document (or in a combination of both). Although identification is required as described in the paragraph above, it is not necessary to reproduce the text of the evaluation methods/evaluation activities in other documents. For example, an ST is not required to include the full text of the evaluation methods and evaluation activities from a PP to which it claims conformance.

4.2 Deriving evaluation methods and evaluation activities

In general, defining evaluation activities and evaluation methods can start either from an SAR, aiming to make some or all parts of its work units more specific, or from an SFR, aiming to define specific aspects of work units related to that SFR.

When starting from an SAR, the process is as follows.

- Identify the relevant ISO/IEC 18045 work units from which at least one individual evaluation activity or groups of evaluation activities shall be derived;
- For each work unit from which an evaluation activity is derived:
 - define the new evaluation activities in terms of the specific work to be carried out and evaluation criteria as described in [6.2](#) (including, if required, pass/fail criteria as described in [6.2.8](#));
 - group evaluation activities into an evaluation method if necessary;
 - state the rationale for the new evaluation activities and the evaluation method under which they are grouped as described in [5.2.10](#) and [6.2.10](#).

EXAMPLE 1 A rationale can include reference to the developer action, and content and presentation elements of the work units from which they are derived.

A process for starting from an SFR is as follows:

- identify the relevant SFR,
- identify the SARs (from ISO/IEC 15408-3 or a set of extended SARs, or both) to be addressed for that particular SFR, and the corresponding ISO/IEC 18045 work units,
- define the new evaluation activities in terms of the specific work to be carried out and evaluation criteria as described in [6.2](#) (including, if required, pass/fail criteria as described in [6.2.8](#)). For example, evaluation activities can be defined to:

ISO/IEC 15408-4:2026(en)

- examine the presentation of a specific SFR in the TOE Summary Specification [derived from class ASE (Security Target (ST) evaluation) (see ISO/IEC 15408-3:2026, Clause 9)],
- examine the presentation of the SFR in the guidance documentation [derived from class AGD (Guidance documents) (see ISO/IEC 15408-3:2026, Clause 11)],
- to carry out specific tests of the SFR [derived from class ATE (Tests) (see ISO/IEC 15408-3:2026, Clause 13)].
- map the affected work units for the SARs to the new evaluation activities;
- state the rationale for the new evaluation activities, and the evaluation method under which they are grouped, as described in [5.2.10](#) and [6.2.10](#).

Although an author may choose to start from SARs or SFRs, it is noted that SARs ultimately cover all SFRs. Starting from SFRs as described here is a technique that can be useful when clarifying the detail of how an SAR applies to a particular SFR, and that can be useful for presenting SFRs alongside the description of their evaluation activities.

It is not required to have a 1:1 mapping between work units and new evaluation activities, and the actual correspondence is documented in a rationale (as described in [5.2.10](#)). The derivation may be made in terms of individual work units or groups of work units, and this is depicted in [Figure 2](#). In case a) of [Figure 2](#), the author maps each work unit from ISO/IEC 18045 to a corresponding evaluation activity, while in case b), the author maps different numbers of work units and evaluation activities, while still addressing all aspects of an action (i.e. the collection of work units).

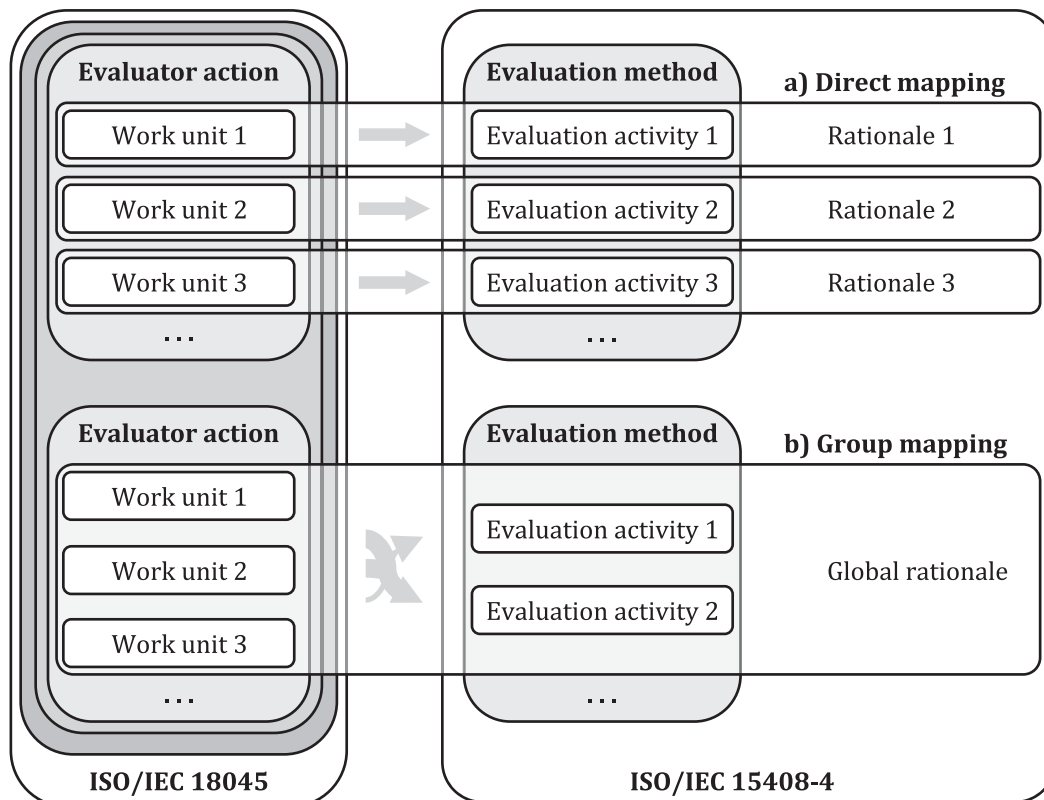


Figure 2 — Alternative approaches to mapping CEM to derived evaluation activities

Other approaches are possible depending on the content of the specific work units and evaluation activities: even where the same number of work units and evaluation activities exist, a simple 1:1 mapping is sometimes

ISO/IEC 15408-4:2026(en)

not possible and therefore a mapping at the action level can be appropriate. Some more detailed mapping situations are described in the examples below.

NOTE These examples assume that the evaluation activities described are being defined by a community that can judge the suitability of the rationale for completeness of the evaluation activities. The examples are concerned only with the form and structure of the mappings, not with the nature or acceptance of the completeness rationale.

EXAMPLE 2 For a TOE type that includes both software and hardware, additional evaluation activities can be defined to deal with the manufacturing environment and its processes. Considering the ALC_DVS (Developer environment security) (see ISO/IEC 15408-3:2026, 12.5) family, a possible approach is to adopt all the existing ALC_DVS (Developer environment security) (see ISO/IEC 15408-3:2026, 12.5) work units for the software development environment and to define additional evaluation activities for each of the relevant hardware and manufacturing aspects. These aspects can include extensions of the normal ALC_DVS (Developer environment security) (see ISO/IEC 15408-3:2026, 12.5) scope to additional items such as protection of hardware design in the development environment, secure transfer of software from the development environment to the manufacturing environment, security of the manufacturing site, and protection of the manufactured product while awaiting delivery. They can also include new aspects related to objects and processes that arise only in the manufacturing environment, such as:

- confirming that the firmware used on a manufacturing line is reliably obtained from the authorized version created on the firmware build system;
- checking configuration management of test programs for testing the TOE on the manufacturing line;
- confirming that processes to disable test or debug interfaces on the TOE operate correctly and reliably;
- examining the physical and logical security of key management systems used to inject keys or certificates into the TOE during manufacture.

In this example, the original ALC_DVS.1.1E (see ISO/IEC 15408-3:2026, 12.5.4) action is mapped to include all the new evaluation activities. An alternative approach is to define additional evaluation activities for each individual work unit for ALC_DVS.1.1E (see ISO/IEC 15408-3:2026, 12.5.4), identifying the additional activities to cover the manufacturing environment for that work unit.

EXAMPLE 3 Another example can be if AVA_VAN.1 (Vulnerability survey) (see ISO/IEC 15408-3:2026, 14.3.3) vulnerability analysis is applied to a particular type of TOE, and there is a specific requirement to achieve consistency in the public domain vulnerability sources used. A possible approach is to define an evaluation activity that covers the AVA_VAN (Vulnerability analysis) (see ISO/IEC 15408-3:2026, 14.3) work unit dealing with searching public domain sources by specifying the particular sources to be used. It is possible to do this with particular searches to be carried out and decision criteria for selecting a resulting list of potential vulnerabilities to be analysed and tested. In this example the original AVA_VAN.1-3 (see ISO/IEC 18045:2026, 16.3.1.5.2) work unit is mapped to the new evaluation activity.

EXAMPLE 4

- For an evaluation method to be used with hardware such as an integrated circuit, evaluation activities can be defined to examine the circuit's architecture, defining required inputs that give the evaluator specific details about the operations and information available through the circuit's interfaces. The definition of these required inputs can then make clear that the relevant interfaces include the circuit's physical surface, its executable programming instructions, and its communication interfaces.
- Further evaluation activities within the evaluation method can examine the circuit's resistance against physical probing in order to prevent manipulating or disabling TSF features.
- For testing activities, evaluation activities within the evaluation method can define a required input that presents the circuit's design as a flow chart of security functions permeating through the circuit's subsystems. The flow chart can then be used by the evaluator to create test cases and to confirm the test coverage of the circuit.

EXAMPLE 5

- For a TOE type such as a network device that provides cryptographically verifiable firmware updates, evaluation activities can give specific details of how the evaluator is required to review the Security Target and guidance documentation to confirm certain specific characteristics required of the cryptographic update process.
- Other evaluation activities can define specific test cases covering the verification of the current firmware, the availability of updates, fetching updates, verifying the source of the updates using cryptographic signatures, and the use of specific types of invalid update in order to test the TOE's acceptance functions.

4.3 Verb usage in the description of evaluation methods and evaluation activities

Where a verb is defined in ISO/IEC 15408-1 then the description of evaluation activities shall use those verbs only in accordance with the definitions. Alternative verbs may be used in an evaluation method for use in its evaluation activities provided that the alternative verbs are defined in the evaluation method. Any such verb definition shall make clear the extent to which evaluator judgement (as opposed to simple checking) is involved.

EXAMPLE An evaluation method that includes automated test generation for a protocol can define a verb “cover”, applied to enumerated types in a protocol parameter, to mean trying all defined and undefined values of the parameter within the available parameter length. Then evaluation activities can be written in forms such as “The evaluator shall cover the PaymentMode field”.

4.4 Conventions for the description of evaluation methods and evaluation activities

Conventions used in ISO/IEC 15408-3 and ISO/IEC 18045 support consistency within, and between, the descriptions of evaluation methods and evaluation activities.

All work unit and sub-task verbs are preceded by the auxiliary verb “shall” and by presenting both the verb and the “shall” in bold italic type face. The auxiliary verb “shall” is used only when the provided text is mandatory and therefore only within the work units and sub-tasks. The work units and sub-tasks contain mandatory activities that the evaluator shall perform in order to assign verdicts.

Guidance text accompanying work units and sub-tasks gives further explanation on how to apply the work units and sub-tasks in an evaluation.

5 Structure of an evaluation method

5.1 Overview

An evaluation method and its constituent evaluation activities are defined for use in a particular evaluation context. For example, separate evaluation methods may be defined for specific technology areas which can range from specific functions up to specific product types or even in extreme cases, for a specific product when the product is evaluated for unique features but where there is a requirement to have the product evaluated using a separately defined method that supports visibility, repeatability and reproducibility of the evaluation.

EXAMPLE Evaluation contexts for which separate evaluation methods can be defined are:

- specific product types like network devices, smart cards, biometric devices, mobile devices;
- specific security functions reused for multiple product types, such as cryptographic functions, cryptographic protocols, digital certificate validation, identification and authentication schemes.

An evaluation method comprises a collection of individual evaluation activities, with additional information about the way in which the evaluation activities collectively meet a goal related to an identified evaluation context.

The description of an evaluation method includes:

- identification of the entity that is responsible for definition and maintenance of the evaluation method;
- the intended scope of the evaluation method, identifying the objective for deriving the evaluation activities in the evaluation method, the evaluation context in which it is intended to be applied, and any known limitation of, or aspects not intended to be covered by, the evaluation method;
- any tool types and/or evaluator competences required to carry out the evaluation activities contained in the evaluation method;
- any requirements for reporting on the results of applying the evaluation method;

ISO/IEC 15408-4:2026(en)

- identification of each work unit in ISO/IEC 18045 (or equivalent for an extended SAR) that is addressed by the evaluation activities in the evaluation method;
- identification of any extended SARs from which an evaluation method is derived (if applicable);
- any additional verbs used in the description of evaluation activities in place of verbs defined in ISO/IEC 15408-1.

Further description of the content, including identification of which content elements are mandatory, and how content elements may be distributed between evaluation method and its evaluation activities, is given in [5.2](#) and [6.2](#) and is summarized in [Table 1](#). Where a content element is optional (e.g. identification of specific evaluator competences, or required tool types), then that part may simply be omitted from the relevant definition: it is not necessary to include a blank section.

5.2 Specification of an evaluation method

5.2.1 Overview

An evaluation method is specified in terms of the information identified in [5.2.2](#) to [5.2.12](#). No specific format is required for providing or presenting this information, except where stated for individual elements in [5.2.2](#) to [5.2.12](#). The purpose of specifying the description of an evaluation method in [5.2.2](#) to [5.2.12](#) is to ensure that the assurance techniques used in an evaluation can be unambiguously identified, and that the evaluation method is used appropriately (in the context for which it was intended) and in a way that supports consistent evaluation results.

In general, the description of an evaluation method can be taken to include the descriptions of the individual evaluation activities that it contains. This means that aspects of the evaluation method description may be deduced from the evaluation activity descriptions.

[Figure 3](#) illustrates the content described in this document for an evaluation method. It does not define a mandatory structure for describing an evaluation method.

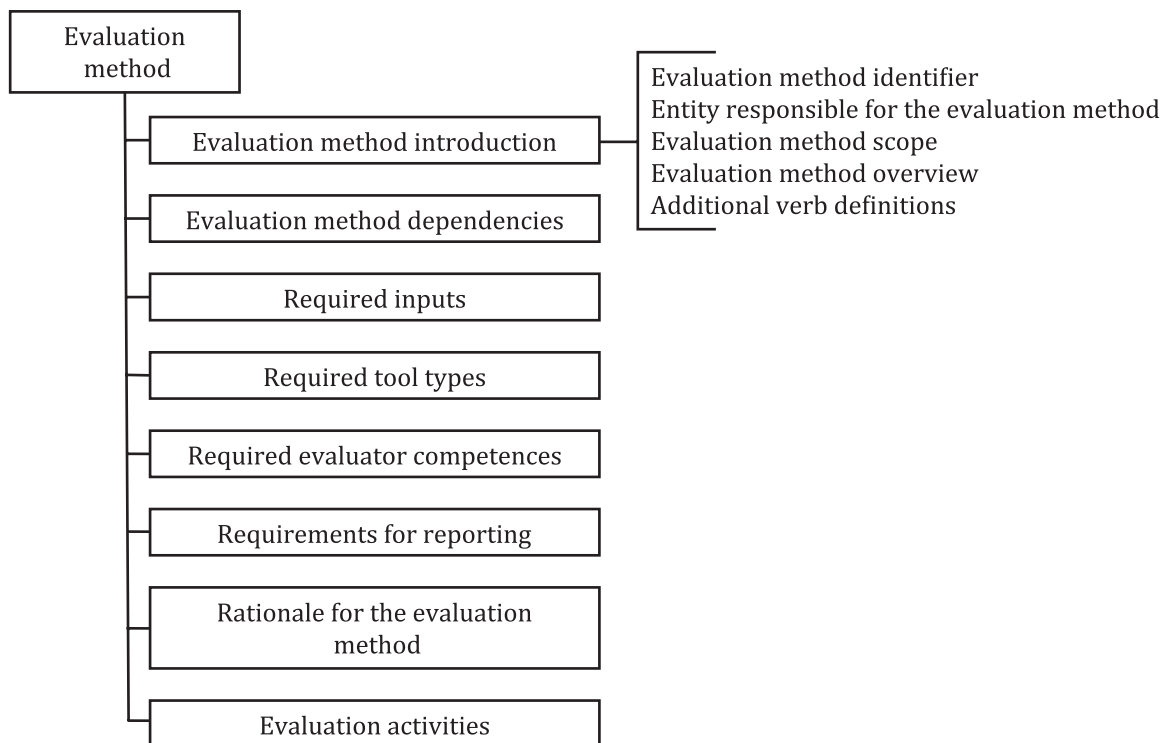


Figure 3 — Contents of an evaluation method

ISO/IEC 15408-4:2026(en)

The contents shown in [Figure 3](#) are described in more detail in [5.2.2](#) to [5.2.12](#) and [6.2](#). A summary of the mandatory and optional requirements for specifying evaluation methods and evaluation activities is given in [Table 1](#).

Table 1 — Distribution of content between evaluation methods and evaluation activities

Content element	Evaluation method	Evaluation activity
Identifier	Mandatory	Mandatory
Entity Responsible	Mandatory	Not applicable
Scope	Mandatory	Not applicable
Dependencies	Optional	Optional
Required inputs	Mandatory	Mandatory
Required tool types	Optional	Optional
Required evaluator competences	Optional	Optional
Requirements for reporting	Optional	Optional
Rationale	Mandatory	Mandatory
Evaluation activities	Mandatory	Not applicable
Additional verb definitions	Optional	Not applicable
Objective	Not applicable	Mandatory
Evaluation activity links to SFRs, SARs and other evaluation activities	Not applicable	Optional
Assessment strategy	Not applicable	Mandatory
Pass/fail criteria	Not applicable	Optional

5.2.2 Identification of evaluation methods

The definition of an evaluation method shall include a unique identifier in order to unambiguously identify the set of evaluation activities to be applied in any given evaluation. An identifier shall be assigned at the evaluation method level (rather than just at the level of the evaluation activities it contains), reflecting the fact that an evaluation method is intended to be applied as a whole, and is subject to rationale and defined purpose and objectives at this level. If a set of evaluation activities has been grouped into an evaluation method, then it shall only be identified as the same evaluation method when the complete set of evaluation activities in the evaluation method is used, with the same rationale as contained in the original evaluation method. If there is a need to divide the evaluation method into smaller subsets of evaluation activities, then a separate evaluation method, with its own rationale, shall be defined for each subset.

EXAMPLE 1 A unique identifier expressed by the title and version number of a supporting document or PP containing the evaluation method.

EXAMPLE 2 An identifier obtained from a registration authority.

As described in [5.2.10](#), an evaluation method may be overlain by another evaluation method (e.g. for use in other PPs or PP-Modules). In such a case, if the original evaluation method rationale still holds (as described in [5.2.10](#)), then the identifier of the original evaluation method shall be used. However, if the rationale is changed as part of the overlay, then a separate identifier defined in the relevant PP-Module, PP-Configuration or PP shall be used. The intention here is to ensure that a significant change to the rationale results in a different identifier being used.

5.2.3 Entity responsible for the evaluation method

The definition of an evaluation method shall state the entity that is responsible for the definition and maintenance of the evaluation method.

EXAMPLE Examples of responsible entities are evaluation authorities, standards bodies, industry working groups, or technical communities.

ISO/IEC 15408-4:2026(en)

5.2.4 Scope of the evaluation method

The definition of an evaluation method shall describe its scope, including:

- the objective of the evaluation method in terms of a brief statement summarizing the assurance goals and a high-level statement of how these are implemented by the evaluation activities within the evaluation method;
- the evaluation context in which the evaluation method is intended to be applied. For example, this can describe a TOE type such as a smart card or network device, or a type of function such as cryptographic functions using certain algorithms and modes applied to certain types of data transmission and data storage;
- any known limitation of the evaluation method, or aspects not intended to be covered by the evaluation method.

Evaluation activities can be defined to apply specifically to one or more SFRs. When an evaluation method includes such SFR-specific evaluation activities, then a subsection of the scope shall identify the individual SFRs that the evaluation method is defined to address and the location where the SFRs are defined (e.g. ISO/IEC 15408-2 or extended SFRs defined in a PP). For extended SFRs that are not defined in ISO/IEC 15408-2, the identification of the location is particularly important since the same SFR name can be used in different sources to refer to SFRs with different content (if the evaluation method is not specific to any SFRs, then this subsection is not required).

Similarly, evaluation activities can be defined to apply specifically to one or more extended SARs (i.e. SARs that are not defined in ISO/IEC 15408-3). When an evaluation method includes such evaluation activities, then a subsection of the scope shall identify the relevant extended SARs and the location where they are defined (e.g. in a PP). As with extended SFRs, the identification of the location is particularly important since the same SAR name can be used in different sources to refer to SARs with different content (if the evaluation method does not apply to any extended SARs, then this subsection is not required).

NOTE The rationale for completeness of the evaluation method (see [5.2.10](#)) can give further information relevant to the scope of the evaluation method.

5.2.5 Dependencies

The definition of an evaluation method shall describe any dependencies on:

- other evaluation methods,
- evaluation activities, or
- some of the generic actions in ISO/IEC 18045.

EXAMPLE An evaluation method that relies on information obtained from some other developer action element in ISO/IEC 15408-3 or some action in ISO/IEC 18045.

Dependencies may be identified either at the level of the evaluation method, or at the level of an individual evaluation activity contained within the evaluation method.

5.2.6 Required input from the developer or other entities

The definition of an evaluation method shall identify any developer input required to perform the evaluation activity. This may be done either at the level of the evaluation method, or at the level of an individual evaluation activity included in the evaluation method. The description of the inputs may also be made by reference to those defined for the generic SAR from which the evaluation activities are derived, as defined in ISO/IEC 15408-3 (or the equivalent generic definition if dealing with an extended SAR).

EXAMPLE The inputs for an evaluation method dealing with media encryption TOEs can define a requirement for description of particular details of a key hierarchy.

ISO/IEC 15408-4:2026(en)

5.2.7 Required tool types

If the evaluation activities require any tool types, then those shall be listed as part of the definition of the evaluation method. The tool types may be identified either at the level of the evaluation method, or at the level of an individual evaluation activity contained within the evaluation method.

5.2.8 Required evaluator competences

An evaluation method may identify specific evaluator competences required for its evaluation activities (see ISO/IEC 19896-3^[3]). If specific evaluator competences are identified, then this may be done either at the level of the evaluation method, or at the level of individual evaluation activities contained within the evaluation method (or a combination of both).

5.2.9 Requirements for reporting

The description of the evaluation method may include a description of reporting requirements. This description may be given at the level of the evaluation method, at the level of individual evaluation activities, or at both levels.

EXAMPLE 1 The evaluation method level can give general reporting requirements, but with some evaluation activities also requiring particular observations, justifications, or answers to specific questions to be included.

Any stated requirements for reporting shall be consistent with the requirements for the evaluation technical report in ISO/IEC 18045, and any other standards required for the conduct of the evaluation.

EXAMPLE 2 An example of another standard that can be required for the conduct of an evaluation is ISO/IEC 17025.

The reporting requirements may specify the reporting to be included in the evaluation technical report (ETR) as described in ISO/IEC 18045, but may also define content for other output reports to be produced.

EXAMPLE 3 There can be separate reports defined for public distribution and for more limited distribution (e.g. the developer, evaluator and evaluation authority).

Where more than one report is defined in this way, the reporting requirements for the evaluation method (including those for individual evaluation activities) may then specify the aspects to be reported in each of the output reports.

If an evaluation method does not require reports or report details other than those given in the work units from which it is derived (or if all the additional reporting requirements are stated in the evaluation activities), then this section is not required.

5.2.10 Rationale for the evaluation method

A rationale shall be given to show that the derivation of the evaluation activities in an evaluation method, from the original work units in ISO/IEC 18045, is appropriate.

NOTE 1 In the case of an extended SAR, references to work units in ISO/IEC 18045 apply instead to work units in the relevant methodology definition for the extended SAR.

This rationale may be given either at the level of the evaluation method, or at the level of individual evaluation activities. If the evaluation activities contained in the evaluation method do not have individual rationales according to [6.2.10](#), then the evaluation method shall include a rationale for the derivation of evaluation activities from work units in ISO/IEC 18045. That rationale may contain an explanation of why work units were reworked for the scope and depth of an evaluation of a specific technology or TOE type. The rationale shall further state how the evaluation activities it contains address all aspects of the evaluator action elements in ISO/IEC 15408-3 to which they apply. It shall also justify that the manner in which the action elements or work units are addressed is complete with respect to the evaluation context in which the evaluation method is intended to be applied.

If an evaluation activity has been derived from an extended SAR, the rationale shall justify that the evaluation activity corresponds to the description of the work units for that extended SAR. The methodology defined in

ISO/IEC 15408-4:2026(en)

ISO/IEC 18045 for evaluating extended component definitions requires work units to be included as part of the definition of an extended SAR. This applies to families:

- APE_ECD (Extended components definition) (see ISO/IEC 15408-3:2026, 7.6),
- ACE_ECD (PP-Module extended components definition) (see ISO/IEC 15408-3:2026, 8.6), and
- ASE_ECD (Extended components definition) (see ISO/IEC 15408-3:2026, 9.6).

The rationale may, if appropriate, identify specific assumptions that are made for the evaluation context.

In cases when different sources of requirements are combined, such as where PP-Modules are used with a base PP in a PP-Configuration, the evaluation activities from each source (e.g. evaluation activities for each base PP/PP-Module and evaluation activities for each component of the PP-Configuration) are combined and applied to the whole of the resulting TOE. As part of the combination, an evaluation method may be overlain by another evaluation method, subject to a justification for any changes made by the overlay such that a rationale for the resulting evaluation method is still given. An overlay exists where the scope of more than one evaluation activity from different sources is the same. The reason for the overlay is to make the resulting evaluation method more specific to the TOE when the two parts are used together (in this example the parts are a base PP and a PP-Module, but other cases can arise such as when a package is used in a PP and a more specific evaluation method defined for the PP overlays a more generic evaluation method defined for the package).

NOTE 2 Although by default the evaluation activities apply to the whole of the resulting TOE, the definition of the evaluation methods or evaluation activities can define limits for their application. For example, evaluation activities can be defined specifically for cryptographic operations that are used in the context of certain secure channel protocols: these evaluation activities would not then apply to the same cryptographic operations when used in the context of protecting stored data.

EXAMPLE Evaluation activities for generic secure channels supported by the TOE can be defined in a base PP for a network device TOE, including evaluation activities for generic secure channels supported by the TOE. A PP-Module can be defined for certain remote management operations on network devices, using a specific secure channel type (e.g. specifying particular operations or particular protocols). The evaluation activities for the PP-Module then overlay the evaluation method for the base PP, meaning that the PP-Module evaluation activities replace the base PP evaluation activities for the particular remote management activities covered in the PP-Module (other secure channel capabilities are still subject to the evaluation activities in the evaluation method for the base PP).

The effect of an overlay is that one or more of the following changes are made to the underlying evaluation method:

- a) an underlying evaluation activity can be removed – typically this is because the evaluation activity is no longer relevant (such as where some of the available selection values in a base PP SFR are removed by a PP-Module);
- b) an underlying evaluation activity can be refined by adding more specific details (which can make the activity stricter) – typically this is done to reflect additional detail in the evaluation context (such as where detail is added to the context of a PP by a functional package);
- c) an additional evaluation activity is defined – typically this is done to reflect additional evaluation context (such as from additional detail added to the context of a PP by a functional package, or an additional SAR added in a PP-Configuration).

NOTE 3 A special case arises where an underlying evaluation activity is changed to correspond to augmentation of an associated SAR – typically this is done to reflect substitution of an existing SAR with a hierarchically higher SAR in a PP-Configuration. In such a case, depending on the new content of the hierarchic SAR, there can be a combination of adding detail as in b) and adding further evaluation activities as in c).

The rationale for the resulting evaluation method may be based on allowances already made for the overlay in the original evaluation method rationale (i.e. where the rationale for the overlay is already included in the original evaluation method definition), or else the more specific evaluation method (e.g. in the PP-Module) may include a separate rationale dealing with its effect on the original evaluation method (e.g. in the base PP). Where the overlaying evaluation method (e.g. the PP-Module) includes a separate rationale, this shall show that the resulting evaluation method preserves the relevant aspects of the overlain evaluation method,

ISO/IEC 15408-4:2026(en)

taking into account the context in which the combined parts are required to be used. For the case of PPs used in combination, the same principle applies: either the original evaluation method describes the permitted variations according to the context in which it is applied, or else the resulting overlain evaluation method deals with the effect on the original evaluation method.

The rationale for overlaying evaluation activities may be a separate section or may be included as part of an assurance rationale or security requirements rationale as described in ISO/IEC 15408-1.

5.2.11 Additional verb definitions

See [4.3](#) for information on the use of additional verbs.

5.2.12 Set of evaluation activities

The evaluation activities contained in the evaluation method shall be defined using the structure defined in [Clause 6](#).

6 Structure of evaluation activities

6.1 Overview

At the level of an individual evaluation activity, the emphasis of the specification is on ensuring that the evaluation activity shall have a clear objective, clear pass/fail criteria (if required), and that any dependencies on other evaluation activities are identified. This is intended to support understanding of the evaluation and hence consistent application of the activity in each evaluation.

As stated in [5.2](#) and summarized in [Table 1](#), some of the details to be specified for evaluation activities may be included at either the evaluation method level or at the level of individual evaluation activities.

It is intended that the contents of evaluation activities may be given in various formats, including a format that consists of, for example, nothing more than a short narrative description of a test or an analysis activity (e.g. to confirm that user documentation describes the secure generation of credentials for use with a protocol). Furthermore, some evaluation activities may be grouped together and content elements described for the group as a whole rather than repeated for each individual evaluation activity. Each content element of an evaluation activity is described in more detail in [6.2.1](#) to [6.2.10](#), and a summary of the mandatory and optional status of each element is summarized in [Table 1](#).

6.2 Specification of an evaluation activity

6.2.1 Unique identification of the evaluation activity

Evaluation activities shall be uniquely identified within their source document. The source document shall itself be uniquely identified. Where evaluation activities have been grouped into an evaluation method then the individual evaluation activity identifiers are defined in addition to an identifier for the evaluation method as a whole (see [5.2.2](#)).

6.2.2 Objective of the evaluation activity

The objective of performing the evaluation activity shall be stated. This may be stated with reference to SFRs and SARs as discussed in [6.2.3](#) and to the pass/fail criteria in [6.2.8](#). However, it is also important that the statement of the objective supports an evaluator in understanding the flexibility and limitations on varying the evaluation activity to fit a specific TOE.

ISO/IEC 15408-4:2026(en)

6.2.3 Evaluation activity links to SFRs, SARs, and other evaluation activities

Where an evaluation activity is related to specific SFRs (possibly to specific instances of SFRs in another document such as a package, PP or PP-Module), then this shall be identified as part of the evaluation activity definition.

EXAMPLE An evaluation activity can be related to an SFR stated in a particular PP with partial completion of an assignment to limit the acceptable values that can be used in a conformant ST.

Similarly, the relationship to specific SARs shall be identified [this may be achieved via the rationale for derivation from the work units of the original SAR (see [5.2.10](#) and [6.2.10](#)) unless there is additional information to be given about the relationship].

Where an evaluation activity depends on completion of another evaluation activity, then the dependency and the other evaluation activity shall be identified as part of the definition of the dependent evaluation activity (dependencies may be identified either at the level of the evaluation method, or at the level of an individual evaluation activity).

6.2.4 Required input from the developer or other entities

As stated in [5.2.6](#), additional detail may be specified regarding the required format and content of the inputs to an evaluation activity. This additional detail is generally used to support precise specification of the evaluation activity and its pass/fail criteria (this may be done either at the level of the evaluation method, or at the level of an individual evaluation activity).

If an evaluation activity does not require other input other than those defined in the work unit from which it is derived, then this section is not required.

6.2.5 Required tool types

If performing the evaluation activity requires any tool types in order to complete the activities, then these tool types shall be defined as part of the definition of the evaluation activity. The definition of the tool type shall include sufficient detail to enable a tool of that type to be obtained or recreated in order that the evaluation activity can be consistently carried out with respect to the evaluation activity description and its pass/fail criteria (this may be done either at the level of the evaluation method, or at the level of an individual evaluation activity).

If an evaluation activity does not require specific tool types other than those given or implied in the work unit from which it is derived, then this section is not required.

6.2.6 Required evaluator competences

As stated in [5.2.8](#), an evaluation method may identify specific evaluator competences required for its evaluation activities (see ISO/IEC 19896-3[3]). If specific evaluator competences are identified, then this may be done either at the level of the evaluation method, or at the level of individual evaluation activities contained within the evaluation method (or a combination of both).

6.2.7 Assessment strategy

This section of an evaluation activity shall provide guidance and details on how to perform the activity. It includes, as appropriate to the content of the evaluation activity:

- how to assess the input from the developer or other entities for completeness with respect to the evaluation activity;
- how to make use of any tool types required (potentially including guidance for the calibration or setup of the tools);
- guidance on the steps for performing the activity.

ISO/IEC 15408-4:2026(en)

Allowing some room for technology-specific adaptation is important for most evaluation activities. Finding the right balance between a precise specification of the assessment strategy and the allowed room for such adaptation is important to ensure objective and reproducible results on the one hand, and meaningful results on the other hand. When the developer has more flexibility regarding how to implement the functional requirement(s), then the evaluation activity definition shall allow more room for adapting the evaluation to different potential implementations. In those cases, the assessment strategy shall provide general guidance on how to perform a TOE-specific refinement and adaptation rather than specifying every detail of the actions the evaluator shall perform. In general, deviations/refinements from an evaluation activity (i.e. omitting things required in the evaluation activity) are not allowed.

An assessment strategy can consist of several stages that the evaluator is required to perform, in which case those stages shall be specified with the expected outcome of each stage. Some stages may depend on the result of previous stages and in this case the assessment strategy shall also define what the evaluator does if one of the stages does not produce the expected result. Examples for those cases are to return to a previous stage with some modified input, terminate the evaluation activity indicating what to document as the result of the activity, or continue with another stage.

Depending on the evaluation context and the nature of the evaluation activity itself, an assessment strategy may be brief and may form part of the general description of the evaluation activity (e.g. the description of how to conduct a particular test or analysis action).

6.2.8 Pass/fail criteria

This section of an evaluation activity allows definition of criteria that the evaluator uses to determine whether the evaluation activity has demonstrated that the TOE has met the relevant requirements or that it has failed to meet the relevant requirements. In some cases, it may be suitable to rely on the description of the original work unit from which the evaluation activity is derived but, in other cases, the author of the evaluation activity may decide that it is necessary or beneficial to state more specific criteria. Ultimately, the pass/fail criteria are concerned with determining whether the objective stated for the evaluation activity (see 6.2.2) has been met. If an evaluation activity mandates separate pass/fail criteria, then these criteria shall maximize the consistency of results from carrying out the evaluation activity in different evaluations. Making an explicit statement of specific criteria in this way minimizes the chance of a different evaluator reaching a different conclusion for the evaluation activity, given the same evidence. In general, therefore the pass/fail criteria shall be made as specific as possible.

Ways of achieving specific pass/fail criteria for analysing documents include expressing criteria in terms of the presence or absence of specific features, for example the presence of the detailed configuration of a communication stack or the set of failure triggers of an execution environment, and in terms of “yes/no” answers to specific “closed” questions (perhaps supported by answers obtained to other “open” questions).

Ways of achieving specific pass/fail criteria for tests are to express the criteria in terms of a particular visible result, such as observing successful communication on a channel, or receiving an error message indicating that the channel setup has failed or observing a memory access/setting. A phrase such as “the TOE deletes the data” would generally be a poor choice as a pass/fail criterion because it is not clear how this deletion shall be determined by the evaluator: a better choice is “the TOE returns a 'file not found' error” or “the evaluator uses <a named interface call> and confirms that the file is not present on the file-list returned”. Another method of expressing specific pass/fail criteria for evaluation activities is in terms of determining conformance with specific clauses of an identified standard, or in terms of comparison with a reference model or set of examples such as the attack potential model in ISO/IEC 18045 or a specific attack potential model as defined for some IT product types.

However, it is also recognized that criteria generally are required to allow for differences in implementation details between different TOEs. Therefore, the pass/fail criteria shall also be described in terms of the objective defined for the evaluation activity (see 6.2.2).

If an evaluation activity does not require pass/fail other than those given in the work unit from which it is derived, then this section is not required.

6.2.9 Requirements for reporting

As stated in [5.2.9](#), specific requirements for reporting (in the ETR and possibly in other outputs) may be specified for an evaluation activity. The requirements may be stated at the level of the evaluation method, or the level of individual evaluation activities. At this level, the defined requirements for reporting are generally intended to support visibility and reproducibility of the pass/fail judgement by documenting answers to particular questions, rationale for conclusions, or giving a clear description of the result of a particular test. In particular, where pass/fail criteria are expected to require evaluator judgements then the requirements for reporting shall include recording of specific factors defined to be involved in making the judgment and reaching the pass/fail conclusion.

If an evaluation activity does not require reports or report details other than those given in the work unit from which it is derived, then this section is not required.

6.2.10 Rationale for the evaluation activity

The evaluation activity shall include a justification for its derivation from one or more work units in ISO/IEC 18045 (or equivalent work unit definition for an extended SAR). That justification may contain an explanation why work units had to be reworked for the scope and depth of an evaluation of a specific technology or TOE type. The combination of rationale at the levels of evaluation method (see [5.2.10](#)) and evaluation activity shall justify that the evaluation method addresses all aspects of the action elements in ISO/IEC 15408-3 to which it applies. Additionally, the combined rationale shall describe how the derivation from the original evaluator action elements or work units ensure that the evaluation activity is complete with respect to the evaluation context in which the evaluation activity is intended to be applied.

NOTE The rationale can identify and justify that some aspects are not applicable for its particular evaluation context.

If the evaluation activity defines pass/fail criteria that are different from the work units it is derived from, then the justification shall provide reasons for the new criteria's feasibility and effectiveness.

The rationale may, if appropriate, identify specific assumptions that are made for the evaluation context.

The rationale may be given either at the level of the evaluation method, or at the level of an individual evaluation activity.

Bibliography

- [1] ISO/IEC 15408-5, *Information security, cybersecurity and privacy protection — Evaluation criteria for IT security — Part 5: Pre-defined packages of security requirements*
- [2] ISO/IEC 17025, *General requirements for the competence of testing and calibration laboratories*
- [3] ISO/IEC 19896-3, *Information security, cybersecurity and privacy protection — Requirements for the competence of IT security conformance assessment body personnel — Part 3: Knowledge and skills requirements for evaluators and reviewers according to the ISO/IEC 15408 series and ISO/IEC 18045*



ICS 35.030

Price based on 16 pages